

Sprint 1 — Phase 2 Report

1. CI/CD Pipeline

The pipeline is defined in `.github/workflows/ci.yml`, runs on every push and pull request to `main`, and uses GitHub Actions on `ubuntu-latest` runners. Four jobs run in sequence: `build-and-test` produces the Maven artefact and is a prerequisite for the three security jobs (`sast`, `sca`, `dast`), which run in parallel afterwards.

All runtime secrets live in **GitHub repo secrets** and are referenced via `${{ secrets.* }}` — no value is hardcoded. The variable names mirror those in `backend/.env.example` so a developer's local `.env` and the CI environment share the same contract.

Secret	Used by	Purpose
<code>DB_PASSWORD</code>	<code>build-and-test</code> , <code>dast</code>	PostgreSQL service container password (test + DAST stack)
<code>JWT_SECRET</code>	<code>build-and-test</code> , <code>dast</code>	HS256 signing key (≥ 32 bytes, validated at startup)
<code>ENCRYPTION_SECRET</code>	<code>build-and-test</code> , <code>dast</code>	Seed for the AES-256/GCM key (rejected if blank)
<code>NVD_API_KEY</code>	<code>sca</code>	Avoids NVD rate-limit penalties on Dependency-Check
<code>SONAR_TOKEN</code>	<code>sast</code>	SonarCloud upload token
<code>GITHUB_TOKEN</code>	<code>sast</code>	SonarCloud PR decoration

`DB_URL`, `DB_USERNAME`, `JWT_EXPIRATION` and `kryptos.storage.temp-dir` are plain (non-secret) env values. If `JWT_SECRET` or `ENCRYPTION_SECRET` are missing or too short the application fails fast at startup (validation in `JwtService.getSigningKey` and the `EncryptionService` constructor), so a misconfigured environment cannot silently fall back to insecure defaults.

Job 1 — Build & Test (`build-and-test`)

- Provisions a **PostgreSQL 16 (alpine)** service container (`kryptos_test`, user `kryptos`).
- Sets up **Java 21 (Temurin)** with the Maven cache.
- Runs `mvn verify` (compile, unit tests, package).
- Uploads `backend/target/` as the `maven-target-folder` artefact so the SAST job can reuse the compiled classes.

Job 2 — SAST: SpotBugs + Find Security Bugs + SonarCloud (`sast`)

- Downloads the prebuilt `target/` from `build-and-test`.
- Runs `mvn spotbugs:check -DskipTests` with the **Find Security Bugs** plugin loaded (configured in `pom.xml`: `spotbugs 4.8.6.4`, `findsecbugs 1.13.0`, effort `Max`, threshold `Medium`, `failOnError=false`).
- Uploads the SpotBugs XML report as `spotbugs-report`.
- Runs the **SonarCloud** scanner against project key `mei-desofs-kryptos`, organization `mei-desofs-kryptos` (host `sonarcloud.io`). PRs are decorated via `GITHUB_TOKEN` and the upload is authenticated with `SONAR_TOKEN`.

Job 3 — SCA: OWASP Dependency-Check (`sca`)

- Runs `mvn dependency-check:check -DskipTests` (`dependency-check-maven 10.0.4`).
- `failBuildOnCVSS=9` is set in `pom.xml`; `continue-on-error: true` is set at the workflow level to ensure the SCA report is always published even when a CVE is found.
- Uses `NVD_API_KEY` to avoid rate-limit penalties from the NVD.
- Uploads `target/dependency-check*` (HTML + JSON + XML) as `dependency-check-report` (always, even on failure).

Job 4 — DAST: OWASP ZAP Baseline (`dast`)

- Boots the full stack with `docker compose up -d --build`, exposing the same secrets to the compose file so `docker-compose.yml` can resolve `${DB_USERNAME}`, `${DB_PASSWORD}`, `${JWT_SECRET}`, `${JWT_EXPIRATION}`, and `${ENCRYPTION_SECRET}`.
- Polls `http://localhost:8080/api/auth/login` for up to 5 minutes (60×5 s) until the backend stops returning `502/503/504/000`.
- Runs **OWASP ZAP Baseline** (`zapproxy/action-baseline@v0.14.0`) with alpha rules (`-a`), AJAX spider (`-j`), `-m 5 -T 10` caps, and the baseline rule overrides in `.zap/rules.tsv` tuned for a stateless JWT REST API surface (CSP / CSRF / cookie checks downgraded to `WARN`; injection / transport / disclosure checks stay at `FAIL`).
- Collects `docker compose logs` for both `app` and `db` into `dast-logs/`, then runs `docker compose down -v`.
- Uploads the HTML / Markdown / JSON reports as `zap-report` and the collected logs as `dast-app-logs`.

Artefacts produced per pipeline run

Job	Artefact	Format(s)
<code>build-and-test</code>	<code>maven-target-folder</code>	compiled <code>target/</code> (retention 1 day)
<code>sast</code>	<code>spotbugs-report</code>	XML
<code>sca</code>	<code>dependency-check-report</code>	HTML + JSON + XML
<code>dast</code>	<code>zap-scan-internal</code>	ZAP action default

Job	Artefact	Format(s)
dast	zap-report	HTML + Markdown + JSON
dast	dast-app-logs	plain text logs

2. Domain Functionality

The Kryptos backend follows **Domain-Driven Design (DDD)** with four main aggregates, a secure authentication layer, an immutable audit log, and a file-handling module for import/export.

Aggregates & core domain

Aggregate	Entity	Key fields	Purpose
User	User	id, username, email, password (Argon2), role, active	Account management with RBAC
Vault	Vault	id, name, description, owner	Logical grouping of credentials per user
Credential	Credential	id, serviceName, username, encryptedPassword (AES-GCM), url, notes, vault	Secure credential storage with encryption at rest
Trusted Device	TrustedDevice	id, deviceName, deviceFingerprint, registeredAt, active, user	Device registration for access control
Audit Log	AuditLog	id, action, performedBy, targetResource, details, timestamp, hash, previousHash	Append-only forensic trail

Services, controllers & authorization

Bounded context	Service	Controller	Endpoints	@PreAuthorize
Auth	AuthService — register/login with rate limiting (5 attempts → 15 min lockout)	AuthController	POST /api/auth/register POST /api/auth/login	Public (/api/auth/** permitted in SecurityConfig)
User	UserService — CRUD, role update, activate/deactivate	UserController	GET /api/users GET /api/users/{id} DELETE /api/users/{id} PATCH /api/users/{id}/role PATCH /api/users/{id}/activate	GET /{id}: ADMIN or USER (self) others: ADMIN
Vault	VaultService — CRUD with ownership validation	VaultController	POST /api/vaults GET /api/vaults GET /api/vaults/{id} DELETE /api/vaults/{id}	USER
Credential	CredentialService — CRUD with vault-ownership checks, password encryption	CredentialController	POST /api/credentials GET /api/credentials/vault/{vaultId} GET /api/credentials/{id} DELETE /api/credentials/{id}	USER
Trusted Device	TrustedDeviceService — register (idempotent), list, update, revoke	TrustedDeviceController	POST /api/devices GET /api/devices GET /api/devices/{id} PUT /api/devices/{id} DELETE /api/devices/{id}	USER
Audit	AuditService — write with SHA-256 hash chaining and CRLF sanitization	AuditController	GET /api/audit (paginated) GET /api/audit/action/{action} (paginated)	ADMIN or AUDITOR
File Handling	CredentialImportExportService + FileHandlingService + ImportExportRateLimiter	ImportExportController	POST /api/credentials/import GET /api/credentials/export	USER

Cross-cutting security

- **Password hashing:** Argon2 via `Argon2PasswordEncoder.defaultsForSpringSecurity_v5_8()`.
- **Encryption at rest:** AES-256/GCM/NoPadding with a fresh random 12-byte IV per credential and a 128-bit GCM tag (`EncryptionService`). The key is derived from `ENCRYPTION_SECRET` via SHA-256 once, at startup.
- **JWT authentication:** HS256 with key length validated at sign/verify time (`getSigningKey` throws `IllegalStateException` if `JWT_SECRET` is shorter than 32 bytes). `JwtAuthFilter` validates every request; sessions are stateless (`SessionCreationPolicy.STATELESS`).
- **HTTP security headers:** strict CSP, HSTS with `includeSubDomains` and one-year `max-age`, `X-Frame-Options: DENY` (`SecurityConfig`).

- **Audit log integrity:** SHA-256 hash chain (`previousHash` ← prior entry's `hash`); JPA `@PreUpdate` / `@PreRemove` callbacks on `AuditLog` throw `UnsupportedOperationException` so updates and deletes are blocked at the ORM layer.
- **Secure file handling:** files stored in an isolated temp directory (`kryptos.storage.temp-dir`) with `rwX-----` (0700) directory permissions and `rw-----` (0600) per-file permissions; path-traversal prevention via `verifyWithinTempDir`; secure wipe with 3 passes (2× random + 1× zero fill) before OS deletion; 5 MiB file size cap returning **HTTP 413** at the controller; 50 000 line record limit at the service.
- **Rate limiting:** login endpoint (5 attempts/min/principal → 15 min lockout via `AuthService`) and import/export endpoints (5 requests/min/principal via `ImportExportRateLimiter` → **HTTP 429**).
- **Pagination:** `AuditController.findAll` / `findByAction` accept `Pageable` and return `Page<AuditLog>` (NFR9 — partial: still TODO for user / vault / credential / device list endpoints).

3. Test Plan Execution

`mvn verify` builds **97 unit and slice tests** across 15 test classes.

Test class	Tests	Layer covered
<code>AuthServiceTest</code>	5	Register / login / lockout / failed-login audit
<code>UserServiceTest</code>	5	Role update, soft delete, admin-action audit
<code>VaultServiceTest</code>	6	CRUD + IDOR (<code>findById</code> , <code>delete</code>)
<code>VaultControllerTest</code>	9	MockMvc — auth, validation, 201/204/401
<code>CredentialServiceTest</code>	9	CRUD, encryption, IDOR (3 paths), no-plaintext-in-response
<code>CredentialControllerTest</code>	9	MockMvc — auth, validation, 201/204/400/401
<code>TrustedDeviceServiceTest</code>	6	Register, fingerprint collision, IDOR, revoke, rename
<code>FileHandlingServiceTest</code>	5	Permissions, secure wipe, path traversal, oversize, sanitised filename
<code>CredentialImportExportServiceTest</code>	5	Empty payload, malformed lines, auto-vault, owner-not-found
<code>ImportExportRateLimiterTest</code>	2	Token bucket — 5/min, per-principal isolation
<code>AuditServiceTest</code>	5	Hash chain, sanitization, null/empty details
<code>AuditControllerTest</code>	5	RBAC — ADMIN/AUDITOR 200, anon 401
<code>AuditLogTest</code>	4	<code>@PreUpdate</code> / <code>@PreRemove</code> throw, <code>@PrePersist</code> timestamps
<code>EncryptionServiceTest</code>	13	Roundtrip, tampering, short ciphertext, blank secret
<code>JwtServiceTest</code>	9	Tampered, expired, garbage, wrong user, short secret
Total	97	

Threat-to-test traceability (Sprint 1 `ThreatIdentification.md`)

Risk	Mitigation	Test evidence
R01 Brute force	5 attempts → 15 min lockout	<code>AuthServiceTest.login_shouldLockAccount_afterMaxFailedAttempts</code>
R02 JWT manipulation	HS256 + signature/exp checks in <code>JwtService</code>	<code>JwtServiceTest</code> — tampered (1), garbage (1), wrong user (1), expired (1), short secret (1)
R03 Credentials at rest	Argon2 + AES-GCM	<code>CredentialServiceTest.create_shouldEncryptPasswordAndSave</code> + <code>EncryptionServiceTest</code> (13)
R04 Mass assignment	DTO whitelist — <code>RegisterRequest</code> and <code>UpdateRoleRequest</code> have no extra fields; role endpoint is ADMIN-only	Design-immune (DTOs reject unknown fields; <code>PATCH /role</code> requires ADMIN)
R05 IDOR on credentials	Vault-ownership check on every op	<code>CredentialServiceTest.create/findById/delete_shouldThrow_whenCredentialDoesNotBelongTo</code> (3)
R06 Plaintext leak in errors	Generic exception messages; <code>EncryptionException</code>	<code>EncryptionServiceTest.decrypt_shouldThrow...</code> (3 — tampered, short, invalid)
R07 IDOR on vaults	Owner-scoped repository queries	<code>VaultServiceTest.findById/delete_shouldThrow_whenVaultDoesNotBelongToOwner</code> (2)

Risk	Mitigation	Test evidence
R08 Malicious upload	UUID rename + extension whitelist; 5 MiB cap → 413 at controller	<code>FileHandlingServiceTest.storeUpload_sanitisesFilename</code> + <code>storeUpload_shouldRejectOversiz</code>
R09 Temp file 0644	<code>0700</code> dir + <code>0600</code> files	<code>FileHandlingServiceTest.exportCredentials_filesAreOwnerOnly</code>
R10 IDOR on export	Endpoint takes no <code>vault_id</code> — always exports the caller's data	n/a (impossible to exploit by design)
R11 Export DoS	<code>ImportExportRateLimiter</code> 5/min/principal → 429	<code>ImportExportRateLimiterTest.tryAcquireExport_allowsFivePerMinute_thenThrottles</code>
R12 No secure wipe	3-pass overwrite (random × 2 + zero)	<code>FileHandlingServiceTest.secureDelete_removesFileAndLogsSuccess</code>
R13 Path traversal in wipe	<code>verifyWithinTempDir</code> → <code>IllegalArgumentException</code>	<code>FileHandlingServiceTest.secureDelete_refusesPathOutsideTempDir</code>
R14 Audit log tampering	<code>AuditLog @PreUpdate</code> / <code>@PreRemove</code> throw	<code>AuditLogTest.onPreUpdate/onPreRemove_shouldThrowUnsupportedOperationException</code> + <code>AuditServiceTest.log_shouldBuildHashChain</code>
R15 Log injection	CRLF / control chars stripped in <code>AuditService.sanitize</code>	<code>AuditServiceTest.log_shouldSanitizeDetails</code>
R16 Log flooding (DoS)	Append-only DB writes; rate-limit on auth attempts	(<i>infra-level — load test out of unit-test scope</i>)
R17 Rogue device	Fingerprint collision rejected with 403 + audit	<code>TrustedDeviceServiceTest.register_shouldRejectFingerprintOwnedByAnotherUser</code>
R18 Admin actions not logged	<code>UserService.deleteById</code> / <code>updateUserRole</code> write audit	<code>UserServiceTest.deleteById_shouldSoftDeleteUser</code> (audit verified via <code>verify(auditService).log</code> + <code>updateUserRole_shouldChangeRoleAndSave</code> (asserts <code>USER_ROLE_UPDATE</code> action))
R19 Session hijack export	JWT expiry enforced; export rate-limit	<code>JwtServiceTest.isTokenValid_shouldReturnFalse_forExpiredToken</code> (+ R11 rate-limit test)
R20 Wipe failure not logged	<code>SECURE_WIPE_FAILED</code> audit emitted before throw	<code>FileHandlingServiceTest.secureDelete_refusesPathOutsideTempDir</code> (verifies the audit call)

Coverage summary: Covered: 17 · Design-immune: 2 · Missing: 1 (R16, load-test scope).

Test coverage by category

Test category	Test classes	GR / UR mapping
Authentication	<code>AuthServiceTest</code> (LOGIN, LOGIN_FAILED, logout audit)	GR4, GR5
Session management	<code>JwtServiceTest</code> — expiry, signature, tampering, wrong user	GR7, UR6
Authorization	<code>VaultServiceTest</code> , <code>CredentialServiceTest</code> , <code>TrustedDeviceServiceTest</code> (IDOR); <code>AuditControllerTest</code> (roles)	GR1, GR10, UR1, UR9
Input validation	DTO <code>@Valid</code> exercised in <code>VaultControllerTest</code> / <code>CredentialControllerTest</code> ; <code>AuditServiceTest.log_shouldSanitizeDetails</code>	GR2
Cryptography	<code>EncryptionServiceTest</code> (13), <code>CredentialServiceTest</code> (encrypt mock)	GR6, GR8, UR2, UR4
Business logic	Vault / credential ownership, device revoke, secure wipe	UR1, UR7, GR9
File handling & OS	<code>FileHandlingServiceTest</code> (permissions, wipe, traversal, oversize); <code>CredentialImportExportServiceTest</code> ; <code>ImportExportRateLimiterTest</code>	GR9, UR4
Audit & logging	<code>AuditLogTest</code> (immutability), <code>AuditServiceTest</code> (hash chain), <code>AuthServiceTest</code> , <code>UserServiceTest</code> , <code>TrustedDeviceServiceTest</code>	GR4, GR10, UR5, UR8, UR9, UR10

4. ASVS v5 Compliance

`Derivables/Sprint2/ASVS_5.0_Tracker_Kryptos.xlsx` is the authoritative source. The tracker was re-evaluated end-to-end this sprint against the actual code and tests; every status change is documented in the [Observations](#) and [Reference / Link](#) columns of the relevant chapter sheet.

Status	Count	% of total (345)
Compliant	108	31.3 %
In Progress	37	10.7 %
Not Started	47	13.6 %
Not Applicable	153	44.3 %

Of the 192 in-scope controls (excluding Not Applicable), 108 are Compliant (56.3 %). Per-chapter Compliant counts:

Chapter	L1	L2	L3	Total
V1 — Encoding & Sanitization	4	11	2	17
V2 — Validation & Business Logic	3	3	1	7
V4 — API and Web Service	1	2	4	7
V5 — File Handling	4	3	3	10
V6 — Authentication	7	4	0	11
V7 — Session Management	3	3	0	6
V8 — Authorization	2	1	1	4
V9 — Self-contained Tokens	4	1	0	5
V10 — OAuth and OIDC	2	3	0	5
V11 — Cryptography	3	7	6	16
V13 — Configuration	1	9	2	12
V14 — Data Protection	0	1	0	1
V15 — Secure Coding & Architecture	1	3	1	5
V16 — Security Logging & Error Handling	0	2	0	2
Total	35	53	20	108

The 37 In Progress controls cluster around documentation artefacts and a handful of small hardening items that the engineering implementation already partially supports:

V2	Validation & Business Logic	4 (V2.1.1, V2.1.2, V2.1.3, V2.3.2 – input/limits docs)
V4	API and Web Service	1 (V4.1.4 – explicit HTTP method allowlist)
V5	File Handling	1 (V5.1.1 – upload-feature matrix)
V6	Authentication	1 (V6.1.1 – anti-automation policy doc)
V7	Session Management	1 (V7.1.1 – session timeout doc)
V8	Authorization	3 (V8.1.1, V8.1.2, V8.3.2 – authz docs + role-change delay)
V9	Self-contained Tokens	1 (V9.2.3 – add JWT aud claim)
V11	Cryptography	3 (V11.1.2, V11.4.4 covered; V11.6.1 → KDF hardening)
V12	Secure Communication	2 (V12.2.1, V12.3.2 – TLS termination + JDBC sslmode)
V13	Configuration	4 (V13.1.1, V13.2.2, V13.3.1, V13.4.6 – db least-priv, secret vault, Server header)
V14	Data Protection	7 (V14.1.1, V14.1.2, V14.2.1, V14.2.3, V14.2.4, V14.2.7, V14.2.8 – classification & retention docs)
V15	Secure Coding & Architecture	3 (V15.1.2 SBOM, V15.1.3 resource-intensive doc, V15.2.1 SCA gating)
V16	Security Logging & Error Handling	7 (V16.1.1 logging inventory; V16.2.1, V16.2.2, V16.3.1–V16.3.4 metadata/event docs)

The remaining 47 **Not Started** controls fall into three buckets: missing features that are genuinely out of scope for Sprint 2 (password self-service, MFA, password-reset flow, login notifications, admin session termination, formal cryptographic-policy and key-management documentation, TLS termination configuration in deployment, antivirus on uploads, log shipping to a separate system, OAuth/OIDC controls if we ever adopt them, and the L3 adaptive-security / per-message signature items).

5. Security Requirements vs. Test Traceability

Mapping from Sprint 1 [Derivables/Sprint1/SecurityTestPlanV2.md](#) to the implemented tests.

General Requirements (GR)

ID	Requirement	Test evidence	Status
GR1	Auth + RBAC on all endpoints	@PreAuthorize on every controller; AuditControllerTest verifies ADMIN / AUDITOR / anon	Covered

ID	Requirement	Test evidence	Status
GR2	Input validation & sanitization	DTO <code>@NotBlank/@Email/@Size</code> ; <code>AuditServiceTest.log_shouldSanitizeDetails</code> ; controller tests for <code>400 Bad Request</code>	Covered
GR3	HTTPS / TLS	Enforced at reverse proxy + HSTS header in <code>SecurityConfig</code> — not in unit-test scope	Architectural
GR4	Failed auth attempts logged	<code>AuthServiceTest</code> — <code>LOGIN_FAILED</code> audit verified on bad password and on logout	Covered
GR5	Rate limiting on sensitive endpoints	<code>AuthServiceTest.login_shouldLockAccount_afterMaxFailedAttempts</code> + <code>ImportExportRateLimiterTest</code> (2 tests)	Covered
GR6	Strong password hashing (Argon2)	<code>SecurityConfig.passwordEncoder()</code> returns <code>Argon2PasswordEncoder</code> — architectural; exercised end-to-end in <code>AuthServiceTest</code>	Covered
GR7	JWT expiration validation	<code>JwtServiceTest.isTokenValid_shouldReturnFalse_forExpiredToken</code> (+ tampered/garbage paths)	Covered
GR8	Credentials encrypted at rest	<code>CredentialServiceTest.create_shouldEncryptPasswordAndSave</code> + <code>EncryptionServiceTest</code>	Covered
GR9	Secure wipe of temp files	<code>FileHandlingServiceTest.secureDelete_removesFileAndLogsSuccess</code> + <code>secureDelete_refusesPathOutsideTempDir</code>	Covered
GR10	Audit logs restricted to ADMIN / AUDITOR	<code>AuditControllerTest</code> — ADMIN 200, AUDITOR 200, anon 401	Covered

User Requirements (UR)

ID	Requirement	Test evidence	Status
UR1	User only accesses own vaults / credentials / devices	<code>VaultServiceTest</code> , <code>CredentialServiceTest</code> , <code>TrustedDeviceServiceTest</code> IDOR cases	Covered
UR2	Stored credentials encrypted	<code>CredentialServiceTest</code> + <code>EncryptionServiceTest</code>	Covered
UR3	Register trusted devices	<code>TrustedDeviceServiceTest.register_shouldCreateNewDevice...</code> + fingerprint-collision rejection	Covered
UR4	Import/export does not expose data	<code>CredentialImportExportServiceTest</code> (5) + <code>FileHandlingServiceTest</code> (5)	Covered
UR5	Log of important actions on user account	Audit emission verified in <code>CredentialServiceTest.delete_shouldDeleteAndAudit</code> , <code>VaultServiceTest.delete_shouldDeleteAndAudit</code> , <code>TrustedDeviceServiceTest.revoke_*</code>	Covered
UR6	Session expiration	<code>JwtServiceTest.isTokenValid_shouldReturnFalse_forExpiredToken</code>	Covered
UR7	Admin cannot access user credentials	No admin endpoint exposes decrypted passwords — architectural guarantee	Architectural
UR8	All administrative actions logged	<code>UserServiceTest.deleteById_shouldSoftDeleteUser</code> + <code>updateUserRole_shouldChangeRoleAndSave</code> verify the audit call	Covered
UR9	Auditor read-only on logs	<code>AuditController</code> is read-only; <code>AuditLog @PreUpdate</code> / <code>@PreRemove</code> block writes	Covered
UR10	Audit records immutable	<code>AuditLogTest</code> JPA lifecycle guards + <code>AuditServiceTest.log_shouldBuildHashChain</code>	Covered

6. Phase 2 / Sprint 3 backlog

Carry-over items that are not yet closed:

- R16 — log flooding load test.** No unit test can prove rate limits survive a flood; this requires a k6 / Gatling script against the staging stack and an alert on append-only WAL growth.
- R02 — explicit `alg=none` test.** `JwtServiceTest` covers signature tampering, expiry, wrong user, garbage and short-secret paths. jjwt 0.12.6 rejects `alg=none` by default, but an explicit negative test would close the gap.
- NFR9 — pagination.** Implemented on `AuditController`; still TODO on `UserController.findAll`, `VaultController.findAll`, `CredentialController.findByVault`, `TrustedDeviceController.findAll`.
- TrustedDevice re-authentication on new fingerprint.** Requires an SMTP provider to notify the user; deferred until a mail integration lands.
- ASVS L2 documentation gap.** Of the 37 `In Progress` controls, V14 (data classification + retention, 7 items) and V16 (logging inventory
 - metadata, 7 items) are the cluster to close in Sprint 3 because they unblock GDPR alignment. V8 (authorization documentation, 3 items) and V13 (db least-priv + secrets vault, 4 items) round out the most impactful documentation backlog.
- SAST / SCA gating.** SpotBugs and Dependency-Check run with `continue-on-error: true` / `failOnError=false` today. Tighten to fail the pipeline on HIGH SpotBugs findings and `CVSS ≥ 7` once the open findings backlog is empty.

